



Dossier de sécurité et de conformité

Protection des renseignements personnels · Conformité Loi 25 · Sécurité applicative

Document de référence — Juin 2026 · arriereplanrh.com

1. Conformité à la Loi 25 (Québec)

Consentement explicite

- À la première connexion, chaque utilisateur doit lire et accepter la politique de confidentialité avant d'accéder à la plateforme (consentement horodaté et conservé au dossier).

Droit à l'oubli (anonymisation)

- Anonymisation complète d'un ancien employé en un clic : nom remplacé par un identifiant neutre, courriel désactivé, compte suspendu, notes effacées, pointages et licences anonymisés.
- Chaque anonymisation est elle-même inscrite au journal d'audit avec le détail des données touchées.

Journal d'audit inaltérable

- Plus de 140 points d'audit : chaque action sensible (connexion, modification de dossier, export de paie, changement de politique de sécurité, anonymisation, consultation de documents...) est enregistrée avec l'auteur, son rôle, la date et le détail de l'action.
- Permet de démontrer en tout temps *qui a fait quoi, quand* — exigence centrale de la Loi 25 en cas d'incident.

Minimisation et cloisonnement des données

- Chaque pharmacie ne voit que ses propres données (cloisonnement strict par organisation).
- Les employés n'accèdent qu'à leurs propres renseignements (libre-service « Mon espace »).

Traçabilité des incidents

- Détection des connexions depuis une nouvelle adresse IP avec alerte automatique — identification rapide d'un accès non autorisé (obligation de notification des incidents de confidentialité).

2. Sécurité des comptes et de l'authentification

Mots de passe hachés (bcrypt)	Jamais stockés en clair — même l'équipe technique ne peut pas les lire.
Vérification en 2 étapes (MFA)	Codes TOTP compatibles Google Authenticator ; secrets MFA chiffrés en base de données.
MFA imposable	L'administrateur peut exiger la MFA pour tous les comptes de la pharmacie.
Politique de mot de passe configurable	Longueur minimale, majuscule / minuscule / chiffre / caractère spécial, expiration (90 j, 180 j ou 1 an) avec renouvellement forcé.
Sessions à durée limitée	Jetons JWT expirant après 24 heures — reconnexion obligatoire.

Réinitialisation sécurisée	Code à usage unique envoyé par courriel, valide 15 minutes, maximum 5 tentatives, haché en base.
Alertes de connexion suspecte	Courriel automatique lors d'une connexion depuis une nouvelle adresse IP.
Borne de pointage protégée	NIP à 4 chiffres hachés (SHA-256 + poivre secret) ; verrouillage temporaire après plusieurs NIP invalides (anti-force brute).

3. Chiffrement des données

- **En transit** : toutes les communications passent par HTTPS/TLS (navigateur ↔ serveur).
- **Au repos** : les documents sensibles (certificats de licences professionnelles OPQ) sont chiffrés avec une clé Fernet (AES-128) avant stockage — un accès direct aux fichiers ne révèle rien.
- **Secrets MFA** : chiffrés avec la même infrastructure de clés.
- **Clés et identifiants** : aucun secret n'est inscrit dans le code source ; tout est stocké dans des variables d'environnement sur le serveur uniquement.

4. Contrôle d'accès

- **Rôles hiérarchiques** : superadmin, administrateur, gestionnaire, employé — chacun ne voit que ce qui le concerne.
- **Accès par module personnalisable** : l'administrateur contrôle précisément quels modules chaque rôle (ou chaque personne) peut consulter.
- **Champs sensibles filtrés** : taux horaires, NIP et données RH ne sont jamais renvoyés aux employés non autorisés.

5. GitHub — sauvegarde et intégrité du code

Important : GitHub n'héberge que le code source, jamais les données personnelles. Le code ne contient aucun renseignement personnel ni aucun secret.

- **Dépôt privé** : code visible uniquement par les collaborateurs autorisés.
- **Historique complet et inaltérable** : chaque modification du code est tracée (qui, quand, quoi) — retour possible à toute version antérieure.
- **Chiffrement** au repos et en transit ; détection automatique de secrets accidentellement exposés.
- **Standard de l'industrie** : utilisé par les institutions financières, gouvernements et systèmes de santé (propriété de Microsoft).
- **Continuité d'affaires** : en cas de panne de l'hébergeur, l'application peut être redéployée ailleurs en quelques heures à partir du dépôt.

6. Hébergement des données

- **Situation actuelle** : application déployée sur une infrastructure infonuagique gérée (conteneurs isolés, HTTPS, base MongoDB dédiée).
- **Ce que la Loi 25 exige** : les renseignements personnels peuvent être hébergés hors Québec à condition qu'une évaluation des facteurs relatifs à la vie privée (ÉFVP) démontre une protection adéquate.

Option renforcée planifiée — hébergement 100 % québécois

- OVHcloud (Beauharnois), AWS ou Google Cloud (région Montréal) avec MongoDB Atlas région Montréal.

- Avantage : les données ne quittent jamais le Québec → aucune ÉFVP de transfert requise, conformité simplifiée, argument de confiance pour les pharmacies clientes.
- Sauvegardes automatiques et chiffrement géré inclus avec MongoDB Atlas.

7. Mesures complémentaires

- **Signatures électroniques** conservées avec horodatage au dossier de l'employé.
- **Suivi des licences professionnelles** (OPQ) avec certificats chiffrés et alertes d'expiration.
- **Séparation des environnements** : développement distinct de la production — aucun test sur les données réelles.
- **Gestion des départs** : suspension immédiate du compte et anonymisation possible à la fin de l'emploi.

8. Résumé exécutif

Arrière Plan applique le principe de protection dès la conception (privacy by design) : consentement explicite, chiffrement des données sensibles, authentification forte imposable, journal d'audit exhaustif, droit à l'oubli en un clic et cloisonnement strict par pharmacie. Le code source est sécurisé et versionné sur GitHub (sans aucune donnée personnelle), et l'architecture permet une migration vers un hébergement entièrement québécois pour une conformité Loi 25 maximale.